

ZERO-TRUST CLINICAL INTELLIGENCE

Nightingale AI

Software Product Documentation & Technical Architecture

Verbatim provenance • deterministic safety boundaries • resilient clinical collaboration

PHI
REDACTION

RISK
FLOORS

HUMAN
VERIFY

Zero-Trust AI Posture Enforces Verbatim Provenance and Deterministic Risk Floors

LLMs remain bounded components: deterministic risk floors, grounding, and human verification control clinical safety.

511

Python tests

54

Vitest tests

79.7 ms

Glance View P95

300 ms

SLA budget

GUARDRAIL ENVELOPE

Browser / Voice

untrusted input

**Presidio / spaCy
+ Risk Floors**
deterministic pre-process

Isolated LLM

model_risk

Verify / Ground

maker-checker

$K^+ \geq 6.4$ mmol/L → critical regardless of model output

SAFETY EQUATIONS & POLICY

Highlights quote exact source spans; paraphrasing is prohibited.

risk_floor and model_risk are persisted separately.

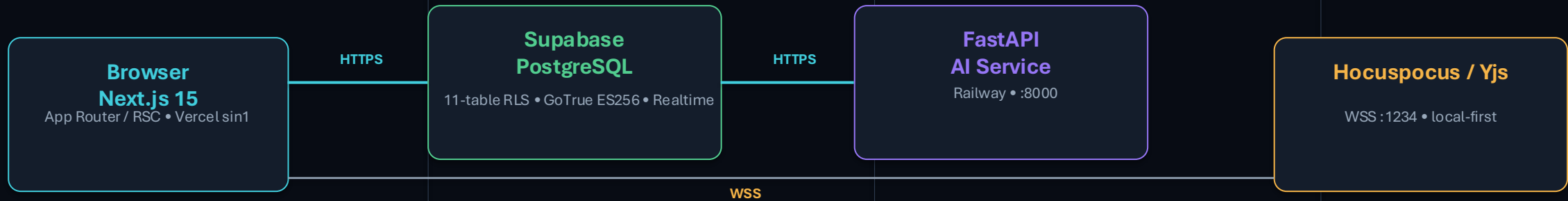
Confidence = 0.50 Agreement + 0.35 Verification + 0.15 Rules.

Confidence < 0.60 withholds non-critical findings for human review.

Critical findings remain visible with an explicit warning.

Multi-Tier Deployment Topology Separates State Isolation, AI Inference, and Real-Time Sync

Independent interaction, collaboration, state, and AI tiers prevent AI-tier outages or compromise from bypassing database RLS.



AI PROCESSING DEPENDENCIES



Reference operational model: local Supabase + local services; hosted Supabase reference instance reported reaped / NXDOMAIN.

State Degradation Protocol Guarantees Data Persistence During Infrastructure Outages

When collaboration is unavailable, direct Supabase persistence protects edits through optimistic concurrency control.

PRIMARY → DEGRADED COLLABORATION STATE MACHINE

`ws://localhost:1234`



`save_care_note_yjs()`

GRACEFUL DEGRADATION CONTRACTS

TipTap/Yjs bypasses WebSocket and persists `yjs_state` in `care_notes`.

Stale OCC writes are rejected; local editor text is preserved.

Missing `GROQ_API_KEY` → `/ready groq_api_key:false` + “Offline Mode (Rule-Derived)”.

Missing `ELEVENLABS_API_KEY` → deterministic mock transcript.

Missing `MESSAGING_PROVIDER` → notifications remain queued.

Amber “Local Only” state appears after 5,000 ms timeout.

Relational Core Standardizes Scoped Data Models Across 11 RLS-Protected Tables

A normalized PostgreSQL foundation anchors multi-tenant care data in an explicit clinic boundary.

ENTITY TOPOLOGY

clinics

tenant boundary

profiles

identity + role

care_notes

clinical record

care_note_assessments

clinician-only

timeline_entries

longitudinal events

highlights

exact quote + risk

note_versions

snapshots

comments

threads

interaction_log

feedback

patient_access_tokens

passwordless auth

message_deliveries

delivery audit

SCHEMA INVARIANTS

Migrations 001–014 squashed into 001_foundation.sql.

profiles roles: patient, staff, clinician, admin.

care_notes: patient_id, clinic_id, version, yjs_state, glance_cache JSONB.

Tenant scope is carried explicitly through clinic_id foreign keys.

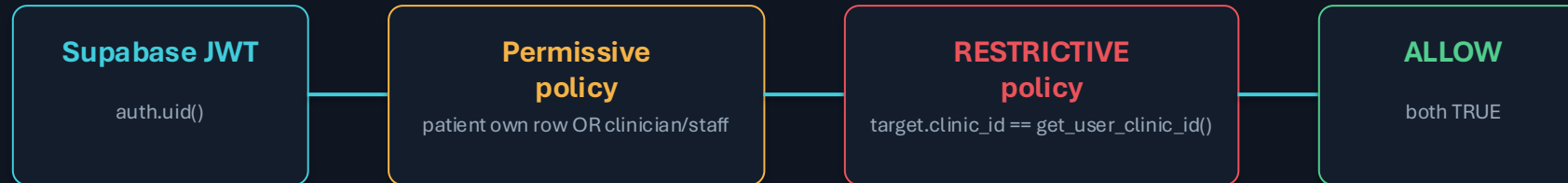
11 tables are RLS-protected.

SECURITY DEFINER Helpers and RESTRICTIVE Policies Enforce Dual-Barrier Multi-Tenancy

Tenant isolation is enforced by a permissive role/identity layer plus a mandatory restrictive clinic boundary.

RLS EVALUATION FLOW

`get_user_clinic_id()` = SECURITY DEFINER lookup of `profiles.clinic_id` for `auth.uid()`



Seed proof: “Nightingale Family” + “Sunrise” clinics; `test_rbac_scope.py` verifies zero cross-tenant leakage.

Patients: own `care_notes` + `patient_visible` timeline only.
Clinicians/Staff: read/write within `profile.clinic_id`.

Structural Table Separation Eliminates Exposure Risks Inherent to Row-Level Security

RLS protects rows, so sensitive clinician attributes are isolated into separate tables and sanitized at write time.

WRITE PATH: SANITIZE BEFORE PERSIST

Clinician saves

Trigger

strip top_items
+
changes_since_last_visit

care_notes

sanitized JSONB

`pin_profile_identity_columns()` blocks self-updates to role / clinic_id.

READ PATH: PATIENT SEES ONLY PERMITTED SURFACE

Patient → care_notes

stripped glance_cache

care_note_assessments

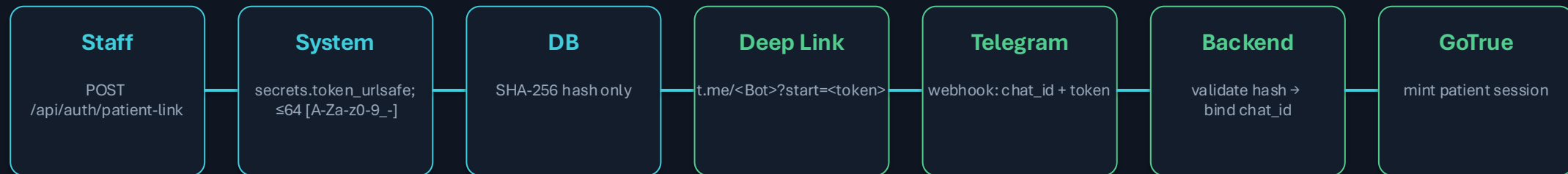
0 patient-facing read policy

Structural separation prevents direct PostgREST access from exposing clinician assessment text.

Cryptographic Token Hashes and Consent-Gated Telegram Flow Secure Non-Email Access

Passwordless patient identity uses URL-safe tokens, SHA-256 at rest, uniform redemption errors, and Telegram consent semantics.

PATIENT LINK SEQUENCE



Uniform redemption failure: "Link no longer valid".

redeem_token rejects non-patient profiles; plaintext tokens are never stored at rest.

Architectural Decision Retains profiles and note_versions to Prevent Call-Site Instability

Schema harmonization was deliberately not performed because the proposed rename/split adds dependency and security-surface risk without functional gain.

PROPOSED VS RETAINED

PROPOSED SPEC

users + patients + versions

RETAINED

profiles (role=patient) + note_versions

DEPENDENCY IMPACT

26

explicit code locations affected

9

active profiles call sites

4

note_versions call sites

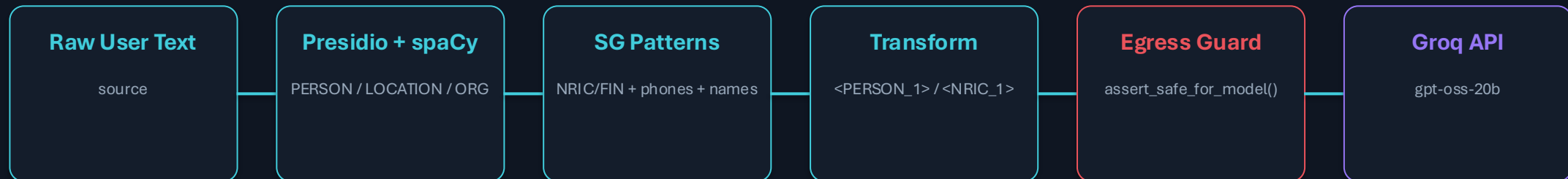
PostgreSQL join hint at risk:
profiles!timeline_entries_author_profile_fkey

Retained unified identity avoids duplicated clinic-scoping logic and parallel RLS surfaces.

Structural Egress Guards Block Un-Redacted PHI Prior to Third-Party LLM Transmission

Every model request receives a final PHI inspection that fails closed before external inference.

PHI EGRESS CONTROL



`assert_safe_for_model(messages)` runs 7 lines before `chat.completions.create`.

Leak detected → `UnredactedEgressError` → request aborted; guard does not silently repair.

Patient-Scoped De-Redaction Blocks Ambient Co-Presence Data Contamination

Only the active chart's patient identity is eligible for restoration; third-party identifiers remain redacted.

AMBIENT TRANSCRIPT

<PERSON_1> Alice Wong
<PERSON_2> Bob Wong [Spouse]
<NRIC_1>
+65 8XXX XXXX

NRIC, phone and email identifiers are never restored—
even for the patient.

ALLOWLIST

Active Chart

profiles.display_name = Alice Wong

Restore only if;
<PERSON_n> matches active patient.

OUTPUT

Alice Wong discussed symptoms with
<PERSON_2> (Spouse).

NRIC withheld.

Non-patient names remain placeholders.

Independent Metric Evaluation Withholds Low-Confidence Claims from Clinical View

Importance, confidence, and clinical risk remain separate persisted dimensions.

0.50

Agreement weight

0.35

Verification weight

0.15

Rules weight

0.60

Abstain threshold

DECISION LOGIC

Highlight

input

**Composite
Confidence**

$0.50A + 0.35V + 0.15R$

≥ 0.60

surface

< 0.60

withhold

Critical

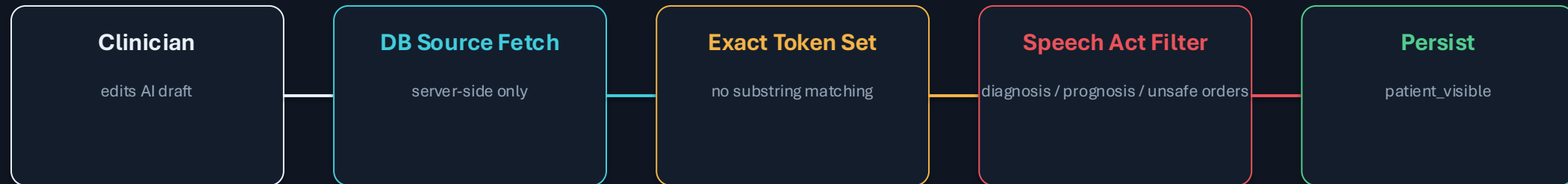
surface + warning

If confidence cannot be computed: UI displays “not assessed” and suppresses confidence badges.

Deterministic Grounding and Prohibited Speech Act Gates Prevent Unvetted AI Output

Patient-facing messages must pass database-sourced grounding, prohibited-speech checks, and RLS visibility controls.

MAKER-CHECKER FIREWALL: /API/AI/SEND-PATIENT-MESSAGE



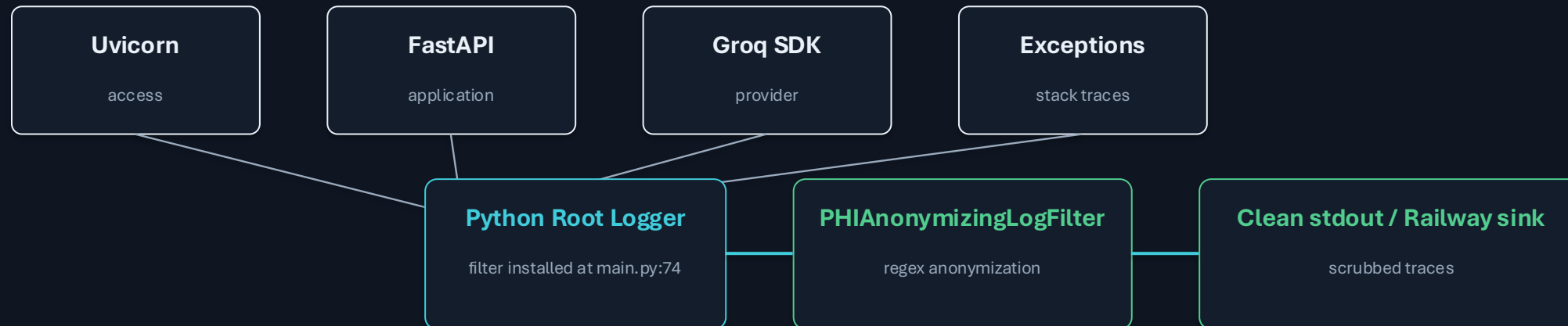
Pass → visibility = patient_visible. **Fail** → HTTP 422 Unprocessable Entity + offending token arrays.

Care-team INSERT policies enforce visibility = internal; patient-visible writes require the maker-checker endpoint.

Root Logger Interception Filters System Traces and Prevents PHI Leakage to Disk

The root logger scrubs framework and server traces before stdout or Railway sinks.

LOG SCRUBBING PIPELINE

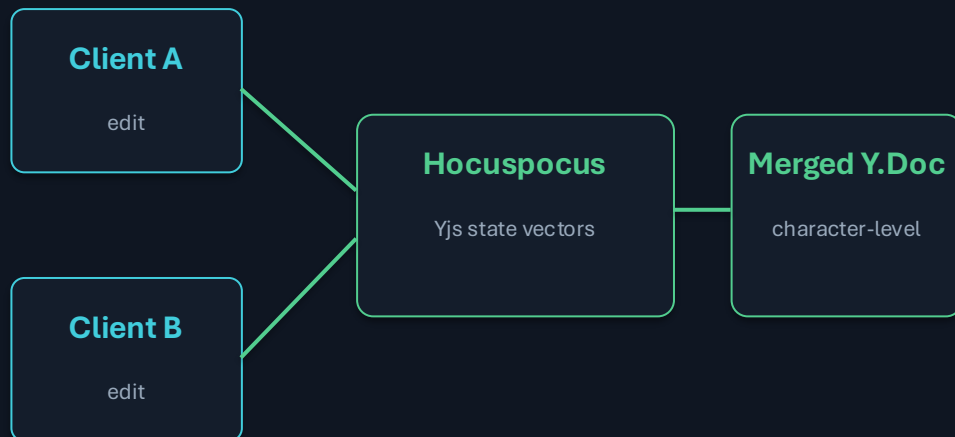


Known limitation: unlabeled free-text names can pass regex scrubbing. **Mitigation:** isolated sinks, retention windows, clinic-specific name deny-lists.

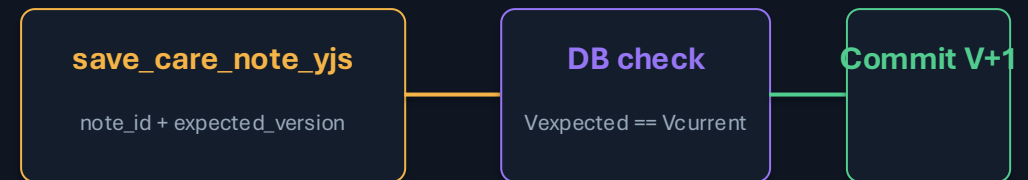
Character-Level CRDT Merging and Optimistic Concurrency Guard Against Concurrent Overwrites

Yjs provides normal-operation collaboration; OCC protects data integrity when the collaboration server is unavailable.

PRIMARY: CRDT SYNC



FALLBACK: OCC COMPARE-AND-SWAP



Mismatch → reject write →
“SAVE BLOCKED: Another user updated this note.” Local TipTap buffer remains intact.

Atomic Database Operations Eliminate Version Number Races and Identity Foreign Key Mismatches

Version numbering moves inside the SQL insert, while system actions use dedicated system profiles rather than invalid UUID literals.

ATOMIC VERSION CREATION

```
INSERT INTO note_versions
SELECT id,
       COALESCE((SELECT MAX(version_number)
                  FROM note_versions WHERE care_note_id = id), 0) + 1,
       yjs_state, auth.uid()
FROM care_notes WHERE id = $1;
```

Single database operation closes the read → increment → insert race window.

IDENTITY INTEGRITY

Legacy system events used changed_by = “system” or all-zero UUID.

profiles.id is a UUID foreign key.

Dedicated system profile rows are provisioned per clinic.

System actions now satisfy the same FK contract as user actions.

Server-Side Pre-Rendered Cache Indexing Achieves Sub-100ms Glance View Response Times

A single indexed JSONB read replaces client-side fetch waterfalls and reaches P95 79.7 ms against a 300 ms budget.

>800 ms

legacy waterfall

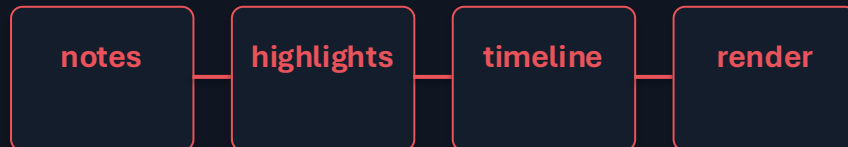
79.7 ms

optimized RSC P95

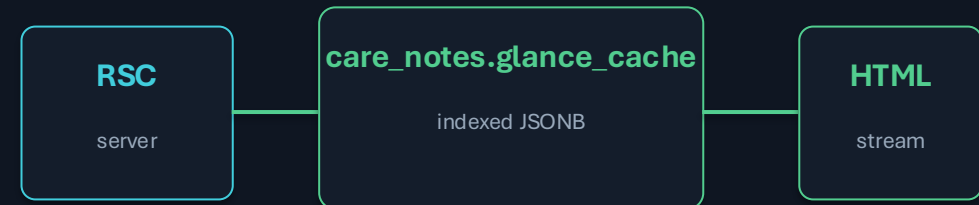
<300 ms

SLA budget

LEGACY



OPTIMIZED RSC PATH



Triggers refresh glance_cache when child highlights or timeline_entries mutate; reads stay off the critical path.

Deterministic UI Rules and Reserved Color Palettes Standardize Clinical Threat Visibility

Progressive disclosure preserves find-in-page and editor state; red is reserved for active clinical threats and safety gates.

CLINICIAN WORKSPACE

CRITICAL FLAGS

3 findings · 1 critical

details / summary

TipTap Editor

68ch line width
Care Plan View remains visible

SAFETY UI RULES

Two-column grid: xl:col-span-4 summary + xl:col-span-8 workspace.

Radix tabs removed so unsynced TipTap state is not unmounted.

Native <details> keeps browser find-in-page behavior.

Every closed summary states explicit contents / counts.

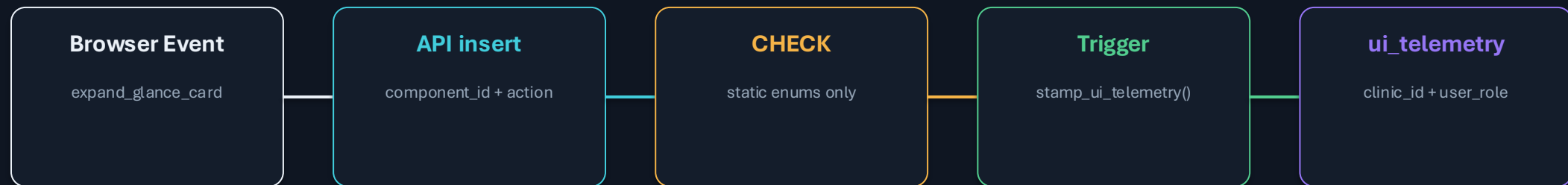
If hasActiveCriticalAlert = TRUE, disclosure controls are disabled.

Red is reserved for critical flags, abnormal labs, blocked maker-checker gates, and retraction warnings.

Append-Only First-Party Telemetry Captures UI Metrics Without Identity or PHI Exposure

Telemetry is structurally unlinkable to patients and users, with enum checks and auth-derived stamping.

TELEMETRY SAFETY PIPELINE



No user_id • no patient_id • no care_note_id

SECURITY DEFINER fix: validate auth.uid() instead of current_user. Non-admins have 0 read access; admins read aggregate clinic metrics through security_invoker views.

Forensic Audit Identifies and Remediates High-Severity Authentication and Migration Defects

Five inherited findings required concrete code and migration changes before the hardened architecture could be trusted.

VULN-01 → VULN-05

ID	Component	Failure	Resolution
VULN-01	app/api/auth/patient-login	Unauthenticated password reset could update arbitrary patient passwords.	Route deleted; authenticated admin session required.
VULN-02	verifyCareNoteClinicScope	Clinic boundary checked; role check omitted, exposing clinician notes to patients.	Explicit role allowlist blocks patient.
VULN-03	Migration 014	Reverted Migration 007 RLS fix and dropped Migration 012 patient readback rules.	001–014 squashed into 001_foundation.sql.
VULN-04	seed_demo_data	4-argument signature shadowed 8-argument version; Sunrise failed to seed.	Single standardized 8-argument seed function.
VULN-05	Migration 013	Re-hardcoded care_plan_score = 0.78 against normalized 0–100 scale.	Normalized scale calculation restored.

AI Endpoint Hardening and Metric Scoping Resolve Unauthenticated Surface Risks

Four AI-service findings span authentication, PHI redaction dependencies, tenant isolation, and test harness reliability.

VULN-06 → VULN-09

VULN-06	ai-service/routers/	All 4 AI endpoints lacked auth: /summarize /highlights /redact /patient_message.	Mandatory JWT middleware across all AI routes (Phase 2).
VULN-07	services/redaction.py	Presidio/spaCy NER dependencies absent; person-name redaction failed.	Install presidio-analyzer + spacy; pin en_core_web_sm (Phase 2).
VULN-08	_compute_learned_score	patient_id ignored; importance signals pooled globally across clinics.	Scope scoring to clinic_id + patient_id (Phase 4).
VULN-09	ai-service/tests	39/40 tests failed during empty-credential fixture setup.	pgharness.py rebuilds throwaway local PG17 clusters (Phase 5).

Clinical Failure Audit Evaluates Communication and Identity Boundaries

Five scenarios expose partial implementation areas while the dual-barrier tenant model survives its adversarial test.

SCENARIOS 1, 2, 3, 11, 12B

01	Phone-only / WhatsApp	PARTIAL	Backend complete; frontend /portal/login trigger missing.
02	Multi-tenant scoping	SURVIVES	get_user_clinic_id() + RESTRICTIVE clinic_id policy.
03	PHI in logs	PARTIAL	NRIC/phone scrubbed; unlabeled names require retention controls.
11	Unreceived appointment links	PARTIAL	sent ≠ confirmed_received; signed webhook receipt advances status.
12b	Unapproved portal content	PARTIAL	patient_visibility requires metadata.patient_gate_verdict = passed.

Algorithmic Conflict Limits Demand Strict Boundaries Around Autonomous AI Safety Claims

Three clinical scenarios show where English-centric rules and explicit string matching do not cover generalized clinical meaning.

SCENARIOS 6, 7, 13

06	Code-switched trilingual audio	PARTIAL	Transcription supports code-switching; risk_rules.py relies on English regex.
07	Late allergy mention	DOES NOT SURVIVE	Batch post-consult audio processing delays allergy flags; no streaming ASR.
13	Penicillin vs blanket denial	DOES NOT SURVIVE	detect_conflicts requires explicit drug-name match; “no known drug allergies” yields 0 conflicts.

Scenario 13 pinned test: `TestBlanketDenialsNotDetected`

Outage-Resilient Banners and Hash Provenance Protect Clinical Scans During Upstream Failures

Timeouts, offline status, OCC, abstention, and source hashes provide explicit system-state signals rather than silent failure.

SCENARIOS 8–16

08

LLM hang**SURVIVES**

Groq 20s server / browser 25s; voice upload 120s.

09

Provider 503**PARTIAL**

Rule-derived offline findings + decoupled Offline Mode banner.

10

Double-edit collision**SURVIVES**

Yjs merge; OCC blocks second fallback save and preserves draft.

14

Metric integrity**SURVIVES**

Separate scores; <0.60 confidence abstains.

15

Self-learning bias**PARTIAL**

Demotion floor after 40+ dismissals; no exploration sampling.

16

Source edit staleness**PARTIAL**

Hash verification flags [SOURCE EDITED — VERIFY NOTE].

Five-Phase Execution Plan Establishes Strict Migration Governance and Phase Exit Gates

Delivery proceeds sequentially; each phase closes against explicit test or benchmark evidence.

SEQUENTIAL PHASE GATES

1	Foundation Data & Auth	001–014 → 001_foundation.sql; RLS; auth fixes	test_rbac_scope.py green
2	AI + Redaction	Presidio/spaCy; SG recognizers; JWT auth	redaction unit tests
3	Real-Time Sync	Hocuspocus/Yjs; OCC; version/UUID fixes	test_concurrent_edits.py green
4	Next.js + Glance	RSC <300 ms; self-learning scoring	latency benchmark + importance test
5	Automated Verification	5 integration suites; throwaway PG	all suites offline
Migration filename rule: YYYYMMDDHHMMSS_name.sql; truncated timestamps can collide in schema_migrations.			

Isolated Test Harness Executes Full Suite Offline Without External Dependencies

QA boots throwaway PostgreSQL 17 clusters and verifies RLS as non-superuser roles.

511

Python AI tests

54

Frontend Vitest

5

Core integration suites

PG17

Throwaway cluster

EXECUTION FLOW

001_foundation.sql**Pytest****PgHarness****initdb
PG17****Non-superuser****5 suites****Tear down**

macOS prerequisite: raise SysV shared memory limits before initdb when required.

FIVE INTEGRATION SUITES

test_rbac_scope.py — tenant isolation + role limits

test_revision_history.py — snapshot immutability

test_highlight_provenance.py — quote hashes

test_concurrent_edits.py — Yjs + OCC

test_self_learning_importance.py — logging + bounds

Strict Production Hardening and Regex Origin Anchoring Block Common Vulnerability Vectors

Production execution depends on exact CORS origins, valid ES256 JWKS, and clean process/environment hygiene.

CORS + AUTHENTICATION

VERCEL_PREVIEW_ORIGIN_REGEX

`https://nightingale-august-frontend-6ktv(-[a-z0-9-]+)?\.vercel\.app`

`allow_origins=["*"]` is prohibited with `allow_credentials=True`.

Literal hyphen before preview suffix is required.

Local Supabase JWTs use ES256 + explicit kid headers.

SUPABASE_JWT_JWK must match `/auth/v1/.well-known/jwks.json`.

OPERATIONAL TRAPS PROTOCOL

01 Shell sourcing

Never source `.env`; JSON quotes can be stripped from `SUPABASE_JWT_JWK`.

02 Concurrent Next build

Do not run next build while next dev is active; `.next` chunks can corrupt.

03 Engine parity

Test harness must use PostgreSQL 17 to match Supabase target environments.

Demo Runbook: Prove the Safety Envelope, Resilience Path, and Human Gate

The product demonstration should move from normal operation to controlled failure and show evidence at every boundary.

ACT 1 — NORMAL CLINICAL FLOW

Open a care note and show the shared longitudinal record.

Trigger a highlight extraction and show exact-quote provenance.

Show risk_floor versus model_risk as separate values.

Demonstrate Glance View and the server-rendered summary path.

Show collaboration through Hocuspocus/Yjs with two editing clients.

ACT 2 — SAFETY + FAILURE INJECTION

Inject PHI into an outbound model payload → egress guard must raise UnredactedEgressError.

Use a low-confidence finding → verify <0.60 non-critical result is withheld.

Attempt an ungrounded patient message → verify HTTP 422 + offending tokens.

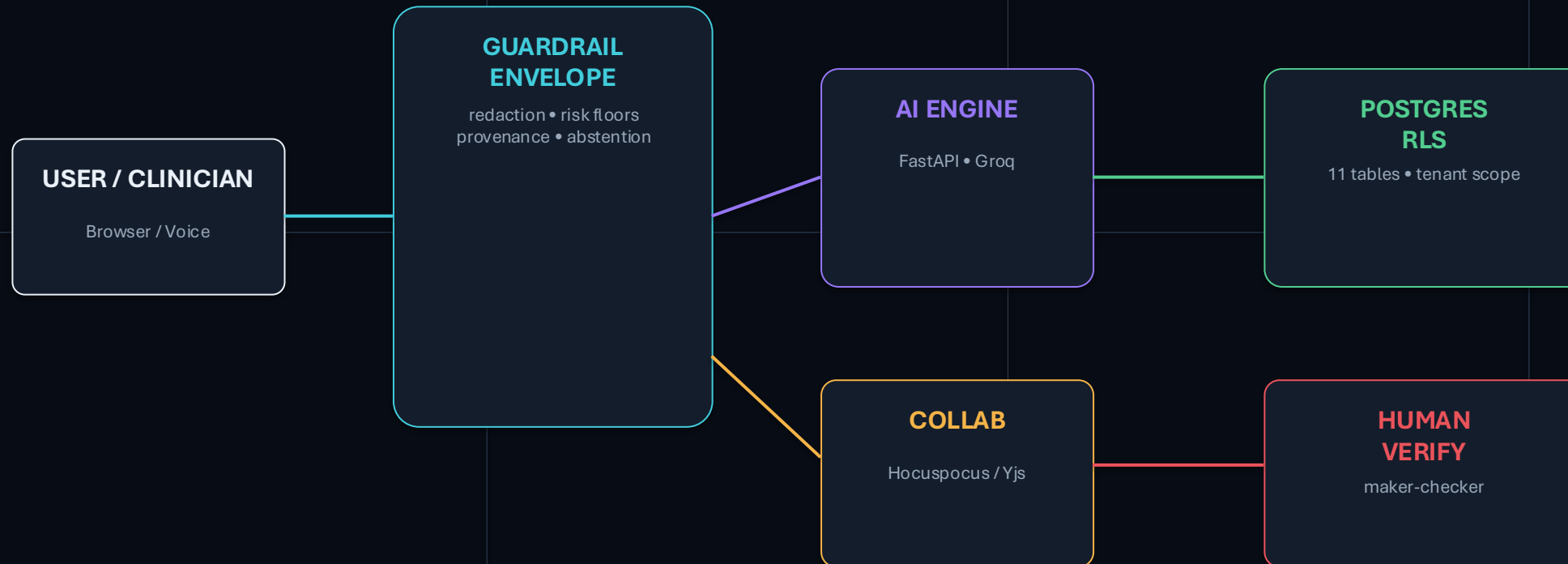
Disconnect Hocuspocus → wait 5 s → show amber Local Only + direct OCC persistence.

Force stale version → show SAVE BLOCKED while local draft remains intact.

Remove GROQ_API_KEY → show Offline Mode (Rule-Derived).

Nightingale's Product Boundary Is the Safety Architecture

The showcase closes by connecting user experience, persistence, AI processing, collaboration, and verification into one evidence-backed control plane.



Core operating principle: no single AI component is trusted to establish clinical truth, authorize patient-visible output, or bypass tenant isolation.

Nightingale's Product Demo